

Experiment no. 07**Use Burp Proxy to Test Web Applications.**

Aim: To use Burp Proxy to test Web Applications.

Theory:

To use Burp for penetration testing, use **Burp's browser**, which requires no additional configuration. To launch Burp's browser, go to the **Proxy > Intercept** tab and click **Open Browser**. A new browser session will open in which all traffic is proxied through Burp automatically. You can even use this to test using HTTPS.

Once you have Burp running and have opened Burp's browser, go to the **Proxy > Intercept** tab, and ensure that interception is turned on (if the button says **Intercept is off** then click it to toggle the interception status). Then, go to the browser and visit any URL.

Each HTTP request made by the browser is displayed in the **Intercept** tab. You can view each message, and edit it if required. When you are done making changes, click the **Forward** button to send the request on to the destination web server. If at any time there are intercepted messages pending, you will need to forward all of these in order for the browser to complete loading the pages it is waiting for.

You can toggle the **Intercept is on / off** button in order to browse normally without any interception, if you require. For more help, see Getting started with Burp Proxy.



As you browse an application with Burp running, the **Proxy > HTTP history** tab keeps a record of all requests and responses, even while the intercept feature is turned off. From this tab, you can review the series of requests you have made.

Select an item in the table to view the full request and response in the message editor panel.

#	Host	Method	URL	Params	Edited	Status	Length	MIME type	Exten
7	https://update.googleapis.com	POST	/service/update2/json?cup2key=10:1...	✓		200	14648	JSON	
8	http://redirector.gvt1.com	GET	/edgedl/release2/chrome_component/...			302	1053	HTML	
12	https://portswigger-labs.net	GET	/index_files/query-2.js			200	85908	script	js
14	https://portswigger-labs.net	GET	/index_files/portswigger-logo.svg			200	8309	XML	svg
15	https://portswigger-labs.net	GET	/index_files/ps-mobile-logo.svg			200	963	XML	svg
17	https://portswigger-labs.net	GET	/Content/Fonts/DroidSans-s-BiyweUP...			200	21722	JSON	woff2
18	https://update.googleapis.com	POST	/service/update2/json	✓		200	1026	JSON	
20	http://redirector.gvt1.com	GET	/edgedl/release2/chrome_component/...			302	1023	HTML	
22	https://update.googleapis.com	POST	/service/update2/json	✓		200	1026	JSON	
23	http://redirector.gvt1.com	GET	/edgedl/release2/chrome_component/...			302	1067	HTML	
25	https://update.googleapis.com	POST	/service/update2/json	✓		200	1026	JSON	
26	http://redirector.gvt1.com	GET	/edgedl/release2/chrome_component/...			302	1027	HTML	
28	https://update.googleapis.com	POST	/service/update2/json	✓		200	1026	JSON	

Request

```
1 GET /index_files/ps-mobile-logo.svg HTTP/1.1
2 Host: portswigger-labs.net
3 Connection: close
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/87.0.4280.88 Safari/537.36
5 Accept:
  image/avif,image/webp,image/apng,image/*,*/*;q=0.8
6 Sec-Fetch-Site: same-origin
7 Sec-Fetch-Mode: no-cors
```

Response

```
1 HTTP/1.1 200 OK
2 Date: Wed, 03 Feb 2021 09:55:06 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Upgrade: h2
5 Connection: Upgrade, close
6 Last-Modified: Fri, 29 May 2020 10:53:20 GMT
7 ETag: "2b1-5a6c740e3a67e"
8 Accept-Ranges: bytes
9 Content-Length: 689
10 Content-Type: image/svg+xml
```

You can use the Inspector to quickly access various features that help you analyze potentially interesting items found in messages. For example, if you drill down into an encoded item in the inspector, it will apply the appropriate sequence of decoding steps so that you can study the value in a more human-readable form.

For editable messages, such as in Burp Repeater, you can also make changes to this decoded value in the Inspector. The relevant encodings will automatically be reapplied to the value as you type.

#	Host	Method	URL	Params	Edited	Status	Length	MIME type	Exten
6	http://www.gstatic.com	GET	/generate_204			204	102		
7	https://update.googleapis.com	POST	/service/update2/json?cup2key=10:1...	✓		200	14648	JSON	
8	http://redirector.gvt1.com	GET	/edgedl/release2/chrome_component/...			302	1053	HTML	
12	https://portswigger-labs.net	GET	/index_files/query-2.js			200	85908	script	js
14	https://portswigger-labs.net	GET	/index_files/portswigger-logo.svg			200	8309	XML	svg
15	https://portswigger-labs.net	GET	/index_files/ps-mobile-logo.svg			200	963	XML	svg
17	https://portswigger-labs.net	GET	/Content/Fonts/DroidSans-s-BiyweUP...			200	21722	JSON	woff2
18	https://update.googleapis.com	POST	/service/update2/json	✓		200	1026	JSON	
20	http://redirector.gvt1.com	GET	/edgedl/release2/chrome_component/...			302	1023	HTML	
22	https://update.googleapis.com	POST	/service/update2/json	✓		200	1026	JSON	
23	http://redirector.gvt1.com	GET	/edgedl/release2/chrome_component/...			302	1067	HTML	
25	https://update.googleapis.com	POST	/service/update2/json	✓		200	1026	JSON	
26	http://redirector.gvt1.com	GET	/edgedl/release2/chrome_component/...			302	1027	HTML	

Request

```
1 POST /service/update2/json?cup2key=10:1...
2 Host: update.googleapis.com
3 Connection: close
4 Content-Length: 1929
5 X-Goog-Update-Appid: cmahnpbhold
6 X-Goog-Update-Interactivity: bg
7 X-Goog-Update-Updater: chromium-
8 Content-Type: application/json
9 Sec-Fetch-Site: none
10 Sec-Fetch-Mode: no-cors
11 Sec-Fetch-Dest: empty
12 User-Agent: Mozilla/5.0 (Windows
```

Response

```
1 HTTP/1.1 200 OK
2 Content-Security-Policy: script
3 Cache-Control: no-cache, no-sto
4 Pragma: no-cache
5 Expires: Mon, 01 Jan 1990 00:00
6 Date: Wed, 03 Feb 2021 09:55:05
7 X-Cup-Server-Proof: 30460221008
8 ETag: W/"30460221008e2059cb527c
9 Content-Type: application/json;
10 X-Daynum: 5147
11 X-Daystart: 6905
12 X-Content-Type-Options: nosniff
```

INSPECTOR

Query Parameters (2)

NAME	VALUE
cup2key	10:1548213833
cup2href	91f1f75655221e5a1120...

Request Headers (12)

Response Headers (17)

As you browse, Burp also builds up a site map of the target application by default. You can view this on the **Target > Site map** tab.

The site map contains all of the URLs you have visited in the browser, and also all of the content that Burp has inferred from responses to your requests (e.g. by parsing links from HTML responses). Items that have been requested are shown in black, and other items are shown in gray. You can expand branches in the tree, select individual items, and view the full requests and responses (where available).

For more help, see Using the Target tool. You can control which content gets added to the site map as you browse by configuring a suitable live scanning task.

Batch D

BEITA

Repeater Sequencer Decoder Comparer Extender Project options User options

Dashboard Target Proxy Intruder

Site map Scope Issue definitions

Filter: Hiding not found items; hiding CSS, image and general binary content; hiding 4xx responses; hiding empty folders

Contents

Host	Method	Path
https://portswigger-labs...	GET	/
https://portswigger-labs...	GET	/cors.ph
https://portswigger-labs...	GET	/cors.ph
https://portswigger-labs...	GET	/cors.ph
https://portswigger-labs...	GET	/crossdc
https://portswigger-labs...	GET	/csp/
https://portswigger-labs...	GET	/csp/?C:
https://portswigger-labs...	GET	/csp/?C:
https://portswigger-labs...	GET	/csp/?C:
https://portswigger-labs...	GET	/csp/?C:
https://portswigger-labs...	GET	/csp/?C:

Issues

- 1 Cross-site scripting (reflected) [2]
- 1 Flash cross-domain policy
- 1 External service interaction (DNS)
- 1 Cross-site scripting (DOM-based) [2]
- 1 Serialized object in HTTP message [2]
- 1 Strict transport security not enforced [4]
- 1 Link manipulation (DOM-based)
- 1 Open redirection (DOM-based)
- 1 Cross-origin resource sharing [2]
- 1 Cross-origin resource sharing: arbitrary c
- 1 Input returned in response (reflected) [2]
- 1 Cross-domain Referer leakage

Burp Suite is designed to be a hands-on tool, where the user controls the actions that are performed. At the core of Burp's penetration testing workflow is the ability to pass HTTP requests between the Burp tools in order to carry out particular tasks.

You can send messages from the **Proxy > Intercept**, **HTTP history**, or **Site map** tabs, and indeed anywhere else in Burp that you see HTTP messages. To do this, select one or more messages, and use the context menu to send the request to another tool.

Repeater Sequencer Decoder Comparer Extender Project options User options

Dashboard Target Proxy Intruder

Intercept HTTP history WebSockets history Options

Filter: Hiding CSS, image and general binary content

#	Host	Method	URL	Params	Edited	Status	Length	MIME type	Exten
6	http://www.gstatic.com	GET	/generate_204			204	102		
7	https://update.googleapis.com	POST	/service/update2/ison?cun2key=10:1		✓	200	14648	JSON	
8	http://redirector.gvt1.com		https://update.googleapis.co...23d0cd2f293cdf8711b2d13613ab			302	1053	HTML	
12	https://portswigger-labs.net	Add to scope				200	85908	script	js
14	https://portswigger-labs.net	Scan				200	8309	XML	svg
15	https://portswigger-labs.net	Do passive scan				200	963	XML	svg
17	https://portswigger-labs.net	Do active scan				200	21722		woff2
18	https://update.googleapis.c					200	1026	JSON	
20	http://redirector.gvt1.com	Send to Intruder		^%I		302	1023	HTML	
22	https://update.googleapis.c	Send to Repeater		^%R		200	1026	JSON	
23	http://redirector.gvt1.com	Send to Sequencer				302	1067	HTML	
25	https://update.googleapis.c	Send to Comparer (request)				200	1026	JSON	
26	http://redirector.gvt1.com	Send to Comparer (response)				302	1027	HTML	

The Burp tools you will use for particular tasks are as follows:

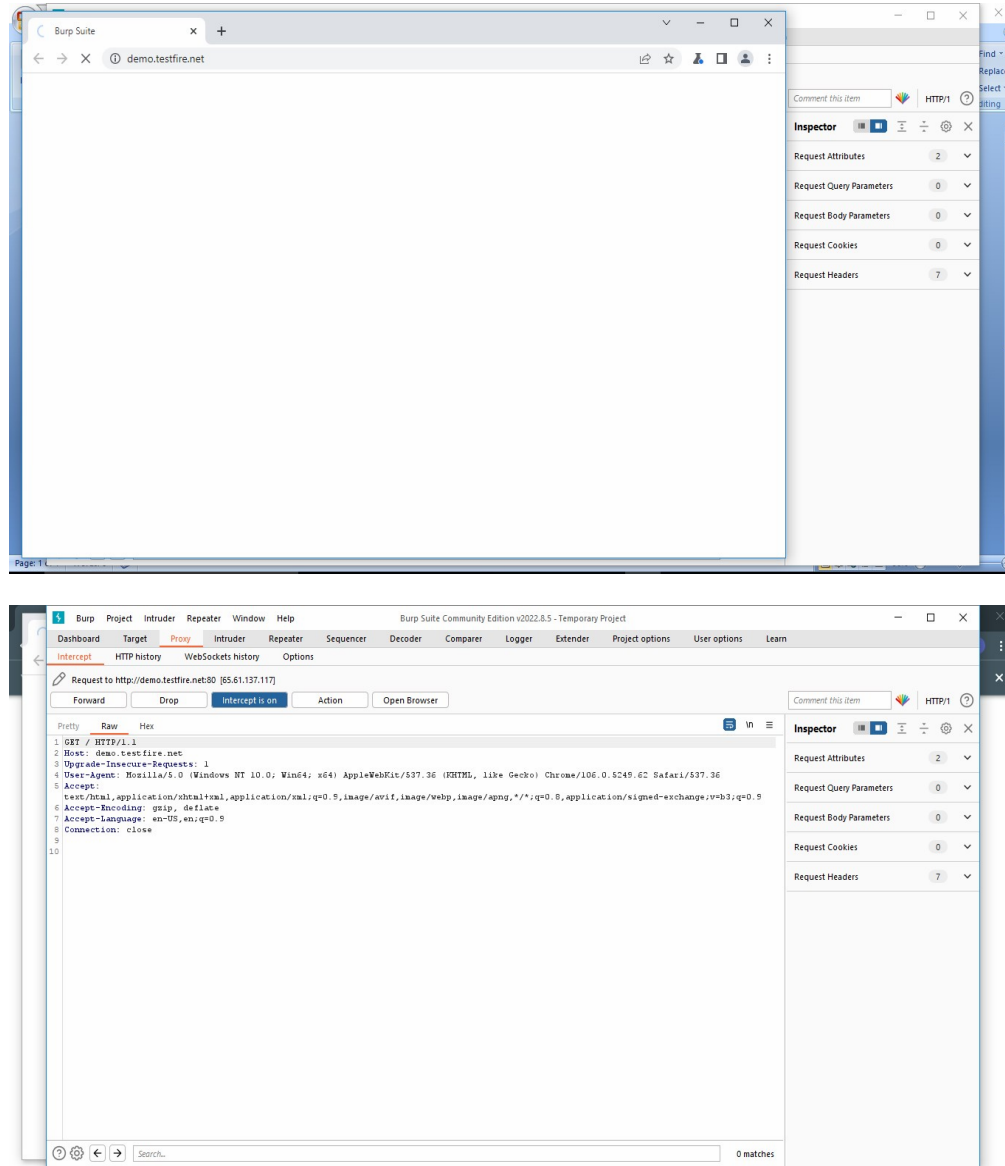
- **Scanner** - This is used to automatically scan websites for content and security vulnerabilities.
- **Intruder** - This allows you to perform customized automated attacks, to carry out all kinds of testing tasks.
- **Repeater** - This is used to manually modify and reissue individual HTTP requests over and over.
- **Collaborator client** - This is used to generate Burp Collaborator payloads and monitor for resulting out-of-band interactions.

Batch D

BEITA

- **Clickbandit** - This is used to generate clickjacking exploits against vulnerable applications.
- **Sequencer** - This is used to analyze the quality of randomness in an application's session tokens.
- **Decoder** - This lets you transform bits of application data using common encoding and decoding schemes.
- **Comparer** - This is used to perform a visual comparison of bits of application data to find interesting differences.

Output:



Conclusion: Thus, I have learnt to use Burp proxy to test web application.